

LVCHAT

Full Monty Audit Report

0 CRITICAL · 1 HIGH · 3 MEDIUM · 8 LOW

Generated: August 15, 2026 at 05:51 PM
Scope: FULL_MONTY
Total findings: 12 · Security: 6 · Performance: 0 · UI/UX: 6

Executive Summary

Metric	Value
Total Findings	12
Critical Severity	0
High Severity	1
Medium Severity	3
Low Severity	8
---	---
Security findings	6
Performance findings	0
UI/UX findings	6
---	---
GPT-OSS-20b findings	0
MiniMax/grep findings	0

Methodology

Security scan (Step 2.5): Two-model parallel approach. Model A — GPT-OSS-20b at 192.168.8.147:1234 (Botbox2): static per-file security review using a 6-thread worker pattern. Model B — MiniMax + local grep sweep: regex/heuristic pass over all source files. Vulnerability classes scanned: SQLi, XSS, CSRF, IDOR,

AuthBypass, HardcodedSecret, SessionHardening, FileUpload/PathTraversal, TimingAttack, Cron/TOCTOU, InfoDisclosure, InsecureDeserialization, OpenRedirect, MissingRateLimit, CORS/OriginCheck, HeaderInjection.

Performance scan (Step 2.6): Same two-model pattern. Classes scanned: N+1, MissingIndex, UnboundedResultSet, SyncExternalCall, MissingCache, AssetBloat, RenderBlocking, ExcessiveDOM, MemoryHotPath, ResourceLeaks, CronInefficiency, ColdStart, FrontendRuntime, NetworkPayload, ConnectionPool, Concurrency.

UI/UX scan (Step 2.7): Same two-model pattern plus Playwright screenshot review where available. Classes scanned: a11y, FormUX, LoadingStates, ErrorUX, InformationArchitecture, VisualConsistency, ResponsiveDesign, i18n, StateFeedback, Discoverability, NativeDialog, DataBinding, DeadUI, ColorContrast, Microcopy, Motion, PrintExport.

Severity scale: Critical (direct exploit / unusability) → High (realistic exploit / visible breakage) → Medium (preconditions / tolerable lag) → Low (defense-in-depth / polish).

Scope rule (CRITICAL): *install/*, *e2e/*, and *tests/* directories are excluded from live-code audit scope. They are development-only and must never reach production. These folders should be manually deleted before any upload.

Security Findings

6 finding(s): 0 Critical · 1 High · 3 Medium · 2 Low

R7-FIX-001	HIGH	test-harness	Freebuff AI fix round
File : Line	tests/smoke.php : 38		
Vulnerable Code	putenv('SETUP_TOKEN=test-setup-token')		
Description	Root cause of the 262-failure baseline: src/Auth.php now requires SETUP_TOKEN for the first registered account to become a		
Remediation	Preserved the security change; updated the harness to set SETUP_TOKEN env + POST field so alice becomes the test admin		

R7-FIX-002	MEDIUM	test-harness	Freebuff AI fix round
File : Line	tests/http_test.php : 98		
Vulnerable Code	SETUP_TOKEN => 'test-setup-token' (spawned server env); setup_token POST field		
Description	HTTP e2e spun up the app server without SETUP_TOKEN, so seeded admin never became admin; also MFA re-enroll/login fl		
Remediation	Pass SETUP_TOKEN to the spawned server; DELETE FROM totp_used_counters between enroll/re-enroll/login steps; sleep		

R7-FIX-003	MEDIUM	bug	Freebuff AI fix round
File : Line	src/services/LegalService.php : 68		
Vulnerable Code	preg_replace_callback('#<(/?)([a-zA-Z][a-zA-Z0-9]*)([!^>]*)>#' ...)		
Description	Sanitizer allowed unquoted attributes through: `<img src=x onerror=alert(1)>` / `<a href=javascript:...>` / `<svg onload=...>` byp		
Remediation	Rewrote tag parser to handle quoted + unquoted attributes, strip all on* event handlers, reject javascript:/data:/vbscript: href/sr		

R7-FIX-004	MEDIUM	bug	Freebuff AI fix round
File : Line	modules/webrtc/EventController.php : 404		
Vulnerable Code	!in_array(\$status['reason'], ['already_member', 'This channel is invite-only.'], true)		
Description	Event landing links were blocked by invite_only even for logged-in members holding the unguessable event slug; guests could		
Remediation	Landing slug now acts as the invite (invite_only no longer blocks), bans/akicks/forbidden still enforced; guests get 401 'Register		

R7-FIX-005	LOW	bug	Freebuff AI fix round
File : Line	bin/ws-server.php : 202		

Vulnerable Code	return (int)(\$st['user']['id'] ?? 0) === \$bellUid && (int)(\$st['user']['guest'] ?? 0) === \$bellGuest;
Description	WS bell notification matched user id only; guest and registered users share a numeric id space, so a guest tab could receive a
Remediation	Match id AND guest flag in the broadcast predicate.

R7-FIX-006	LOW	test-fix	Freebuff AI fix round
File : Line	tests/smoke.php : 1154		
Vulnerable Code	putenv('TRUSTED_PROXY=0'); check('client_ip ignores spoofed headers without TRUSTED_PROXY', client_ip() === '1...		
Description	client_ip() now requires TRUSTED_PROXY to honor X-Forwarded-For / X-Real-IP / CF-Connecting-IP (anti-spoofing hardening)		
Remediation	Tests updated: without TRUSTED_PROXY, spoofed headers ignored (REMOTE_ADDR wins); with TRUSTED_PROXY=1, he		

UI/UX Findings

6 finding(s): 0 Critical · 0 High · 0 Medium · 6 Low

R7-AU D-001	LOW	security	Manual audit sweep round 7
File : Line	src/Database.php : 386		
Vulnerable Code	\$pdo->exec('UPDATE user_sound_prefs SET dm_sound_id = ' . \$keep . ' ...')		
Description	String-concat SQL in the sound_alerts name-dedupe migration. Values are pdo->quote()'d and server-generated (not user input)		
Remediation	No change required; could be rewritten with bound params for consistency.		

R7-AU D-002	LOW	security	Manual audit sweep round 7
File : Line	views/admin/analytics.php : 73		
Vulnerable Code	echo \$body;		
Description	analytics_card() echoes \$body unescaped. All current callers pass chart functions (JSON-encoded data, h()-escaped labels), so		
Remediation	Optional: type the \$body contract as sanitized-HTML and document it; low priority.		

R7-AU D-003	LOW	perf	Manual audit sweep round 7
File : Line	src/controllers/ChatController.php : 864		
Vulnerable Code	sleep(\$interval);		
Description	Long-poll SSE loop uses sleep(\$interval) by design (streaming poll). Verified intentional, not a hang.		
Remediation	None required.		

R7-AU D-004	LOW	perf	Manual audit sweep round 7
File : Line	src/services/CommandRunner.php : 99		
Vulnerable Code	proc_open/shell exec path		
Description	CommandRunner's popen/proc_open/exec execution is admin/CLI-only context with timeout + output streaming; not reachable		
Remediation	None required.		

R7-AU D-005	LOW	uiux	Manual audit sweep round 7
File : Line	views/admin/*.php : 1		

Vulnerable Code	inline style= attributes in ≥9 admin views
Description	Admin views use inline styles (Tailwind utility classes mostly); acceptable for a utility-first design, minor maintainability note.
Remediation	None required (Tailwind convention).

R7-AU D-006	LOW	uiux	Manual audit sweep round 7
File : Line	messenger-web/src/vendor/*.js : 1		
Vulnerable Code	console.log in vendor bundles (selfie-segmentation, livekit)		
Description	console.log hits are all vendored third-party libraries or test harnesses, none in first-party app code.		
Remediation	None required.		